

Caracas, 10 de septiembre de 2026

Señores:

SUPERINTENDENCIA NACIONAL DE ACTIVIDADES HÍPICAS

SUNAHIP

Presente. –

Por medio del presente documento se expone formalmente el **Protocolo y Plan de Seguridad Digital del Sistema de Gestión de Ciberseguridad** que rige sobre la plataforma web **sellatuparley.com**. Este plan ha sido diseñado e implementado con el objetivo de garantizar la integridad, disponibilidad, confidencialidad y trazabilidad de los datos de registro, operaciones de apuestas, saldos, billeteras, pasarelas de pago y la correspondiente información de recaudación fiscal exigida por la ley.

La arquitectura tecnológica de la plataforma se apoya en una infraestructura híbrida compuesta por el proveedor perimetral y red de entrega de contenido (CDN) **Cloudflare**, la plataforma de despliegue elástico y computación en el Edge **Vercel**, y los servicios de origen, base de datos, respaldo y auditoría definidos para la operación.

1. 1. GARANTÍA DE DISPONIBILIDAD

Continuidad de la plataforma para la operación del usuario y la fiscalización del Estado.

Para asegurar que el sistema permanezca disponible las 24 horas del día, los 7 días de la semana, evitando interrupciones que afecten la recaudación fiscal o la actividad del usuario, se aplican los siguientes controles:

- **Arquitectura Serverless y Red Global Distribuida (Edge Network):** La aplicación está desplegada en la infraestructura elástica de Vercel y no depende de un único servidor físico o VPS tradicional. Ante picos de usuarios concurrentes, la plataforma escala horizontal y automáticamente, distribuyendo la carga de trabajo para evitar caídas por saturación de hardware.
- **Mitigación de Ataques de Denegación de Servicio (DDoS):** A través del proxy perimetral de Cloudflare, se cuenta con mitigación de ataques volumétricos en las capas 3, 4 y 7 del modelo OSI. El tráfico malicioso automatizado es detectado y bloqueado en el borde antes de alcanzar los servidores de aplicación o las bases de datos. El cortafuegos puede activar un modo de contingencia restrictivo que obliga al tráfico sospechoso a superar retos de verificación.
- **Plan de Contingencia y Retorno (Rollback Inmutable):** Cada actualización genera un estado único e inmutable. Ante un error crítico de código o configuración posterior a un lanzamiento, la plataforma puede revertirse a una versión estable en menos de treinta (30) segundos. Este control complementa, pero no sustituye, el Plan de Recuperación ante Desastres.
- **Infraestructura de Origen y Replicación:** Los servicios de backend y base de datos se alojan en centros de datos con certificación Tier III o Tier IV, o equivalente verificable, con redundancia eléctrica N+1 o 2N y conectividad redundante multi-homing mediante BGP. La base de datos crítica opera con replicación síncrona Multi-AZ o Multi-Región; se supervisan la salud de las réplicas, la latencia de replicación y la capacidad de conmutación.

RIF. J-40429728-6

- **Plan de Recuperación ante Desastres (DRP):** Se establece un RPO de 0, por lo que no se acepta pérdida de datos de apuestas ni transacciones confirmadas, y un RTO menor a treinta (30) minutos ante una catástrofe lógica o de infraestructura. Ante la indisponibilidad del backend o de la base de datos primaria, el responsable de tecnología declara el incidente, preserva la evidencia, identifica el componente afectado y activa la conmutación automatizada hacia la réplica sana mediante mecanismos de failover de DNS configurados y monitorizados. Antes de reanudar el tráfico se valida el conteo de transacciones, los hashes SHA-256, la consistencia de saldos y el cumplimiento del RPO. Posteriormente se restablecen las integraciones externas, se realizan pruebas funcionales controladas y se emite un informe con causa raíz, tiempos, evidencia y acciones correctivas. El procedimiento se ensaya al menos semestralmente y después de cambios relevantes, dejando un acta auditable.
- **Copias de Seguridad y Restauración:** Se aplica estrictamente la regla 3-2-1: se mantienen al menos tres copias de los datos, en dos medios o tecnologías distintas, y una copia fuera de sitio en una bóveda aislada con retención WORM. Los respaldos se cifran con AES-256, se supervisa su finalización y toda falla genera una alerta e incidencia documentada. Se realizan pruebas de restauración al menos trimestralmente en un entorno aislado no productivo. Cada prueba verifica descifrado, integridad, disponibilidad de la base de datos, consistencia de registros y hashes SHA-256 de una muestra transaccional; se conserva fecha, responsable, copia utilizada, resultado, tiempo empleado, desviaciones y acciones correctivas.

•

2. 2. GARANTÍA DE CONFIDENCIALIDAD

Protección estricta contra el acceso no autorizado a los datos de apuestas, saldos y transacciones.

Para asegurar que los datos transaccionales de los usuarios y los registros de recaudación fiscal permanezcan accesibles exclusivamente a las partes autorizadas, se implementan los siguientes protocolos:

- **Cifrado de Datos en Tránsito (SSL/TLS):** Toda comunicación entre el usuario final y la plataforma se realiza bajo HTTPS con TLS 1.3, mediante certificados gestionados por Cloudflare y Vercel. Las conexiones API entre los servicios de aplicación y las pasarelas de pago o proveedores externos de cuotas o resultados se protegen con autenticación mutua mTLS (Mutual TLS), validando el certificado de ambos extremos y registrando errores de autenticación o negociación segura.
- **Cifrado en Reposo y Aislamiento de Credenciales:** Las tablas, volúmenes y respaldos que contienen apuestas, balances, billeteras, datos de transacción y recaudación fiscal se cifran en reposo con AES-256, incluyendo Transparent Data Encryption (TDE) cuando sea aplicable. Las claves se administran separadamente de los datos, con acceso restringido y registro de operaciones administrativas. Las credenciales, tokens de pasarela y claves API se almacenan como secretos administrados y segregados por ambiente; no se incluyen en código fuente, registros ni artefactos de despliegue.

RIF. J-40429728-6

- **Tokenización de Pagos:** La plataforma no conserva datos sensibles de instrumentos de pago cuando la pasarela autorizada puede tokenizarlos. Se emplea tokenización conforme a las políticas aplicables de PCI-DSS, utilizando identificadores sustitutos para operaciones posteriores y manteniendo los datos del instrumento aislados en el proveedor autorizado.
- **Control de Acceso y Autenticación Centralizada:** Las consolas de administración, proveedores cloud, repositorios y entornos internos requieren autenticación multifactor (MFA/2FA). Los accesos se asignan bajo mínimo privilegio, se revisan trimestralmente y se revocan cuando finaliza la relación o función que los justifica. Las URL internas y ramas de desarrollo permanecen protegidas mediante autenticación; solo se expone la versión de producción autorizada.
- **Protección de Mapas de Código:** Se restringe el acceso público a los archivos de mapeo de código fuente (sourcemaps), reduciendo el riesgo de ingeniería inversa sobre la lógica del negocio y las estructuras de consulta.

1. 3. GARANTÍA DE INTEGRIDAD

Mecanismos para evitar la alteración, manipulación o borrado malicioso de las jugadas y registros fiscales.

Para certificar que la información almacenada en las bases de datos es fidedigna, auditable y no ha sido modificada por agentes externos, se ejecutan las siguientes directivas:

- **Cortafuegos de Capa de Aplicación (WAF - Web Application Firewall):** Se implementan reglas administradas alineadas con OWASP Top 10. El filtro analiza las peticiones HTTP entrantes para bloquear intentos de inyección SQL (SQLi), Cross-Site Scripting (XSS), manipulación de parámetros y otros ataques contra los flujos transaccionales.
- **Protección Contra Bots de Extracción de Datos:** Se mantiene una política de denegación automática para scrapers, bots maliciosos y automatizaciones que abusen de formularios transaccionales. Esto reduce el riesgo de extracción de datos, manipulación automatizada de cuotas o saturación de conexiones.
- **Políticas de Conexión Segura a Bases de Datos (Connection Pooling):** Se utiliza un orquestador intermedio de conexiones que regula el flujo de lectura y escritura hacia la base de datos, controla concurrencia, límites y validación de operaciones para asegurar que cada apuesta se procese y registre de forma segura.
- **Sincronización Horaria y Sellado Criptográfico:** Los componentes que generan, validan o registran apuestas sincronizan su hora con servidores NTP Stratum 1 o fuentes NTP equivalentes de alta confiabilidad. Se supervisa la desviación de reloj y se generan alertas ante diferencias fuera del umbral operativo aprobado. Cada transacción incorpora fecha y hora UTC, identificador único y un hash SHA-256 calculado sobre sus datos relevantes. La validación de la marca de tiempo se ejecuta antes de aceptar la apuesta para impedir registros extemporáneos (past-posting).

RIF. J-40429728-6

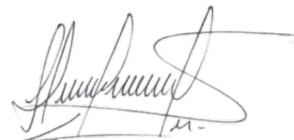
- **Trazabilidad, Custodia de Registros y Respaldos:** Los Build & Function Logs de Vercel se utilizan para diagnóstico operativo, pero no constituyen la evidencia regulatoria definitiva. Los registros transaccionales, de autenticación, autorización, pagos, cambios administrativos, errores y eventos de seguridad se exportan automáticamente y de forma continua a un repositorio central de auditoría con retención WORM (Write Once, Read Many). Durante el período de retención aprobado, los registros no pueden eliminarse ni modificarse por operadores, administradores de aplicación ni roles de auditoría ordinarios. El acceso se controla por roles, toda consulta queda registrada y se conserva evidencia de la correcta exportación de eventos.

Los controles descritos son objeto de evaluación anual de riesgos y de revisión posterior a cambios significativos, incidentes o integraciones nuevas. Los eventos de seguridad se clasifican, investigan y documentan; sus conclusiones se incorporan a los controles técnicos, reglas de monitoreo y capacitación del personal. La empresa conserva las configuraciones, registros WORM, actas de prueba, evidencias de respaldo y reportes de monitoreo disponibles para auditoría por la autoridad competente.

Certificando que la plataforma cumple con los controles de seguridad descritos para la mitigación de riesgos informáticos y la protección de datos financieros, firma conforme:



Ing. Rocky J. Rincon C.
Director de Tecnología
C.I.: 18.326.459



HEIDEGGER MONCADA
DIRECTOR GENERAL
C.I.: 11.197.982